

Méthodologie SIEM & SOC Managé en Freelance

Architecture hybride performante : Production OVHcloud & Archivage Souverain Infomaniak

Spécifications de l'Infrastructure Cible

Serveur de Production :	VPS OVHcloud (8 vCores, 24 Go RAM, 200 Go SSD)
Espace d'Archivage :	Swiss Backup Infomaniak (1 To via protocole SFTP/S3)
Rôle :	SIEM Multi-Tenant pour la supervision de clients freelances

1. Principes Fondamentaux du Multi-Tenancy

Pour héberger plusieurs clients sur une seule et même instance Wazuh sans risque de fuite de données, l'isolation doit être absolue au niveau logiciel :

- **Séparation par index** : Les alertes de chaque client doivent être envoyées dans des index OpenSearch distincts (ex: `wazuh-alerts-4.x-clientA-*`).
- **Contrôle d'accès basé sur les rôles (RBAC)** : Configuration fine des politiques de sécurité et des rôles d'utilisateurs sur OpenSearch Dashboards pour restreindre la visibilité de chaque client à son propre index.
- **Groupe d'agents** : Regroupement des machines par client dans Wazuh pour automatiser le déploiement et la mise à jour des configurations de sécurité (`ossec.conf`) spécifiques.

2. Étape 1 : Préparation de l'espace de stockage externe

La rétention légale imposant souvent la conservation des logs sur une durée d'un an, les 200 Go du VPS OVH s'avèrent insuffisants. Le stockage externe d'Infomaniak servira de destination pour les archives de logs à froid.

1. Se connecter à la console Infomaniak et souscrire à l'offre **Swiss Backup**.
2. Créer un espace de type "**Sauvegarde de serveurs / protocoles standards**" et sélectionner le protocole **SFTP**.
3. Noter précieusement les informations d'authentification générées :
 - Serveur hôte (ex: `*.swiss-backup.infomaniak.com`)
 - Identifiant de connexion
 - Mot de passe associé

3. Étape 2 : Automatisation des sauvegardes et de la purge (VPS)

Wazuh compresse nativement les alertes résolues en fin de journée au format `.json.gz` dans l'arborescence `/var/ossec/logs/alerts/`.

Installation et configuration de rclone

L'utilitaire `rclone` est idéal pour synchroniser efficacement et de manière sécurisée les fichiers locaux avec l'espace Swiss Backup.

```
# Installation de rclone sur le VPS OVH
sudo apt update && sudo apt install rclone -y

# Initialisation de la configuration
rclone config
```

Suivre l'assistant textuel pour ajouter un nouveau dépôt distant (remote) nommé `infomaniak` en sélectionnant le type `sftp` et en renseignant les accès fournis par Infomaniak.

Mise en place du script d'automatisation

Créer un script d'administration système permettant d'exporter les données puis de nettoyer le disque local afin d'éviter la saturation des 200 Go.

```
# Créer le fichier du script
sudo nano /usr/local/bin/backup_wazuh.sh
```

Insérer le code suivant dans le script :

```
#!/bin/bash
# 1. Synchronisation des archives vers Swiss Backup Infomaniak
rclone sync /var/ossec/logs/alerts/ infomaniak:wazuh-archives/ --min-age 2d

# 2. Suppression locale des logs compressés de plus de 14 jours
find /var/ossec/logs/alerts/ -type f -mtime +14 -name "*.gz" -delete
```

```
# Rendre le script exécutable
sudo chmod +x /usr/local/bin/backup_wazuh.sh
```

Planification de la tâche Cron

Planifier le script pour une exécution quotidienne automatique en milieu de nuit :

```
# Ouvrir le planificateur
sudo crontab -e
```

```
# Ajouter la ligne suivante au bas du fichier
0 2 * * * /usr/local/bin/backup_wazuh.sh >/dev/null 2>&1
```

4. Étape 3 : Gestion de la rétention chaude (OpenSearch)

En complément de la purge des fichiers plats, il faut impérativement restreindre la taille de la base de données active (les index OpenSearch) via l'**Index State Management (ISM)**.

Depuis l'interface web de Wazuh, naviguer dans **Management > Dev Tools** et appliquer une règle de cycle de vie (Policy). Cette règle devra automatiquement faire passer l'état des index de Hot à Delete après une période de 14 à 30 jours au choix.

Sécurité & Obligations RGPD (Points Majeurs)

Filtrage réseau : Ne jamais exposer directement les ports d'administration (443, 9200) sur Internet. Utiliser impérativement un reverse-proxy (Nginx) durci et limiter les accès IP via un VPN (ex: WireGuard).

Conformité : Les logs de sécurité contiennent des données personnelles (adresses IP, logs de connexion). Le couple OVHcloud (UE) / Infomaniak (Suisse) garantit la conformité RGPD. Vous devez impérativement signer un contrat de sous-traitance de données (DPA) avec vos clients.